

شركة دايموند لوساطة التأمين
سياسة أمن أنظمة تقنية المعلومات
مايو 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الثمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة أمن أنظمة تقنية المعلومات			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
1ITM0004			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
إدارة تقنية المعلومات			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	29/07/2025	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	29/07/2025	شادن سلطان العتيبي	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	29/07/2025	بدر سعد الشايح	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة أمن أنظمة تقنية المعلومات جزءاً أساسياً في البنى التحتية الحيوية التي تعتمد عليها جميع العمليات التشغيلية والإدارية لضمان حماية هذه الأصول من التهديدات السيبرانية والمخاطر التشغيلية، والامتثال للمتطلبات التنظيمية المعتمدة في المملكة العربية السعودية.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو وضع إطار تنظيمي شامل لضمان أمن وسلامة أنظمة تقنية المعلومات، وتحديد الضوابط الواجب الالتزام بها لتأمين الأنظمة والبنية التحتية الرقمية من الاختراقات أو إساءة الاستخدام. كما تهدف إلى:

2.1.1 منع الوصول غير المصرح به إلى الأنظمة.

2.1.2 حماية البيانات أثناء التخزين والنقل والتشغيل.

2.1.3 تطبيق ضوابط الأمان على الشبكات، البيئات، والأجهزة الطرفية.

2.1.4 ضمان الجاهزية للاستجابة للحوادث.

2.1.5 تعزيز الالتزام التنظيمي.

3. التعاريف:

3.1 دايموند: شركة الوثيقة الماسية لوساطة التأمين.

3.2 أنظمة تقنية المعلومات: كافة البرمجيات، الخوادم، قواعد البيانات، أنظمة التشغيل، الأنظمة السحابية، وأنظمة التحكم المؤسسية التي تُستخدم في تشغيل وإدارة البنية التحتية الرقمية في الشركة.

3.3 الأنظمة الحساسة: الأنظمة التي تحتوي على بيانات مالية، صحية، شخصية، أو سرية تخص العملاء أو العمليات التشغيلية الداخلية.

3.4 البيانات الحساسة: بيانات تحتوي على معلومات شخصية أو مالية أو طبية أو تعاقدية تُعرف أو تخص فرداً أو جهة، وتتطلب حماية خاصة بموجب السياسات التنظيمية.

3.5 بيئات الأنظمة: بيئة التطوير (DEV)، بيئة الاختبار (UAT)، بيئة الإنتاج (PROD)، وكل منها تُستخدم في مراحل مختلفة من دورة حياة الأنظمة.

3.6 Access Point: نقطة الاتصال اللاسلكية التي تتيح الربط بشبكة Wi-Fi داخل المنشأة.

3.7 CVSS (Common Vulnerability Scoring System): نظام عالمي لتصنيف خطورة الثغرات الأمنية.

3.8 DLP (Data Loss Prevention): آلية منع تسرب البيانات، تُستخدم لمراقبة البيانات الحساسة ومنع تصديرها خارج النظام.

3.9 EDR (Endpoint Detection and Response): نظام متقدم للكشف والاستجابة على الأجهزة الطرفية.

3.10 FIM (File Integrity Monitoring): أداة تراقب التعديلات على ملفات النظام الحيوية وتنبه عند التغييرات غير المصرح بها.

3.11 IDS (Intrusion Detection System): نظام كشف التسلل، يُستخدم لرصد الأنشطة غير المصرح بها داخل الشبكة.

3.12 MFA (Multi-Factor Authentication): المصادقة متعددة العوامل، أسلوب حماية يتطلب أكثر من وسيلة تحقق قبل السماح بالدخول.

3.13 RFC (Request for Change): تذكرة تغيير معتمدة تُستخدم لتنظيم وتنفيذ التحديثات البرمجية أو التشغيلية.

3.14 SIEM (Security Information and Event Management): نظام مركزي لتحليل وتجميع الأحداث الأمنية، يساعد في مراقبة الأنظمة واكتشاف التهديدات.

3.15 Tamper Protection: ميزة تمنع التعديل أو إيقاف برامج الحماية على الأجهزة.

3.16 التصعيد الفني: إجراء يُتخذ عند ظهور مشكلة تقنية حرجية، يتضمن رفع الحالة إلى مستوى إداري أعلى لاتخاذ قرار فوري.

3.17 الجهة المالكة للنظام: الإدارة التي تستخدم الأنظمة التقنية بشكل رئيسي وتكون مسؤولة وظيفياً عن تشغيلها، اعتماد التحديثات المقترحة، مراجعة صلاحيات المستخدمين، والتنسيق مع إدارة تقنية المعلومات لضمان الامتثال والتكامل التشغيلي.

3.18 سجل الأجهزة: قاعدة بيانات رسمية تحتوي على كافة معلومات الأجهزة المستخدمة، تُستخدم لأغراض التتبع والمراقبة.

3.19 سجل الحوادث التقنية: سجل إلكتروني أو ورقي يُوثق جميع الحوادث المرتبطة بأمن المعلومات أو الأعطال التشغيلية.

3.20 مشرف تقنية المعلومات: الموظف المسؤول عن إدارة البنية التحتية التقنية، إعداد الشبكات، ضبط الأجهزة، تنفيذ السياسات الفنية، والتنسيق مع الإدارات الأخرى.

3.21 مسؤول الأمن السيبراني: الموظف المسؤول عن مراقبة ضوابط الأمن السيبراني، تحليل السجلات، اكتشاف الثغرات، وتنسيق الاستجابة للحوادث.

- 3.22 مبدأ أقل صلاحية (Least Privilege): مبدأ أمني ينص على منح المستخدمين أقل قدر من الصلاحيات المطلوبة لأداء مهامهم فقط.
- 3.23 نظام إدارة الأصول: نظام إلكتروني لتوثيق ومتابعة أصول تقنية المعلومات (أجهزة، برمجيات، شبكات)، يُحدث دوريًا.
- 3.24 تقرير تحليل الحادث: وثيقة تُعد من قبل مسؤول الأمن السيبراني بعد وقوع حادث، تتضمن تحليل الأسباب، نطاق الأثر، والتوصيات التصحيحية. (يستمر باقي المحتوى كما هو دون تغيير).

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على جميع أنظمة تقنية المعلومات التابعة للشركة بما يشمل:

- 4.1.1 الخوادم المحلية والسحابية.
- 4.1.2 أجهزة الشبكات .
- 4.1.3 أنظمة البريد الإلكتروني، الاتصال، والوصول.
- 4.1.4 بيئات التشغيل والتطوير.
- 4.1.5 أجهزة الموظفين المرتبطة بالشبكة.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات. قسم الأمن السيبراني.

6. الكيانات ذات العلاقة:

- 6.1 كافة الكيانات المملوكة بالكامل إلى شركة داي몬드.
- 6.2 المزودون التقنيون المعتمدون.
- 6.3 الجهات الرقابية (هيئة التأمين، هيئة الأمن السيبراني)



إدارة الجودة والتطوير Quality & Development Management

7. قواعد عامة:

7.1 التكوين الآمن للأنظمة:

- 7.1.1 يجب على إخصائي تقنية المعلومات في إدارة تقنية المعلومات تجهيز جميع الأنظمة التشغيلية وفق تكوينات أمنية معتمدة، وتحديثها بشكل دوري كل 3 أشهر.
- 7.1.2 يُلزم بحذف جميع الحسابات والإعدادات الافتراضية فور تثبيت النظام، بما في ذلك كلمات المرور العامة أو حسابات الضيف.
- 7.1.3 يجب تعطيل جميع الخدمات والمنافذ التي لا تستخدم فعليًا في بيئة الإنتاج، بعد مراجعة فنية معتمدة.
- 7.1.4 تُوثق التكوينات في سجل مشفر ضمن نظام إدارة الأصول التقنية، ويُراجع هذا السجل من قبل مسؤول الأمن السيبراني بشكل ربع سنوي.
- 7.1.5 في حال رصد أي انحراف في التكوينات، يُلزم الفريق التقني بتصحيحه خلال يومي عمل وإعداد تقرير متابعة.

7.2 التحكم في الوصول:

- 7.2.1 يجب أن يُطبق مبدأ "أقل صلاحية" (Least Privilege) لجميع المستخدمين على الأنظمة والتطبيقات.
- 7.2.2 يُمنع منعًا باتًا استخدام حسابات مشتركة أو مشاركة بيانات الدخول بين الموظفين.
- 7.2.3 يجب تفعيل المصادقة متعددة العوامل (MFA) في كل نظام يحتوي على بيانات مالية أو شخصية أو حساسة.
- 7.2.4 تُراجع صلاحيات الدخول كل 3 أشهر من قبل مسؤول نظام الوصول (مشرف تقنية المعلومات)، مع مصادقة النتائج من الجهة المالكة للنظام.
- 7.2.5 في حال اكتشاف صلاحيات زائدة، تُزال مباشرة، وتُوثق الحادثة في سجل الوصول وتُعرض على مشرف تقنية المعلومات.

7.3 الفصل بين البيئات:

- 7.3.1 يجب إنشاء ثلاث بيئات منفصلة: تطوير (DEV)، اختبار (UAT)، وإنتاج (PROD) مع منع مشاركة قواعد البيانات الحقيقية خارج بيئة الإنتاج.
- 7.3.2 يُلزم بتوثيق كل عملية نقل أو ترقية كود بين البيئات، ويتم اعتمادها من مسؤول التغيير.
- 7.3.3 يُمنع على فريق التطوير امتلاك صلاحية مباشرة على بيئة الإنتاج، ويُسمح فقط بقراءة محدودة إن لزم.
- 7.3.4 تُجرى مراجعة فصل البيئات نصف سنويًا.

7.4 أمن الشبكات والبنية التحتية:

- 7.4.1 يجب تطبيق ضوابط جدران الحماية (Firewall Rules) بما يضمن تقليل المنافذ المفتوحة إلى الحد الأدنى.
- 7.4.2 تُفعل أنظمة كشف التسلل (IDS) وأنظمة إدارة السجلات (SIEM) وتُراقب 24/7 من قبل فريق الأمن السيبراني.
- 7.4.3 يجب تحديث مخطط الشبكة وتوثيقه كل 6 أشهر على الأقل، ومراجعتها من مدير الشبكات.
- 7.4.4 يُمنع استخدام أي بروتوكولات ضعيفة (مثل Telnet، FTP)، ويجب الاعتماد فقط على بروتوكولات مؤمنة مثل SSH، HTTPS.
- 7.4.5 أي محاولة ربط شبكة داخلية بشبكة خارجية تتطلب إذنًا مكتوبًا من الإدارة التقنية، ويجب تسجيلها في سجل الاتصالات الشبكية.
- 7.4.6 في حال رصدت محاولة غير مصرح بها لربط الشبكة، يجب على مسؤول الأمن السيبراني إصدار تنبيه فوري، وإبلاغ مشرف تقنية المعلومات خلال ساعة واحدة، وتوثيق الحادثة في سجل الحوادث، على أن تُعرض لاحقًا على لجنة الأمن للمراجعة.
- 7.4.7 يُمنع توصيل أو استخدام أجهزة مثل مبدلات الشبكة أو نقاط الاتصال دون اعتماد رسمي وتوثيق كامل في نظام الأصول.

7.5 التحديثات وإدارة الثغرات:

- 7.5.1 يُلزم بفحص أنظمة التشغيل وقواعد البيانات شهريًا باستخدام أدوات معتمدة (مثل Nessus، Qualys).
- 7.5.2 يجب تطبيق التحديثات الحرجة خلال 24 ساعة، والتحديثات المتوسطة خلال أسبوع.
- 7.5.3 يُمنع تنفيذ أي تحديث في الإنتاج دون وجود تذكير تغيير (RFC) موقعة حسب سياسة التغيير.
- 7.5.4 تُصنف الثغرات حسب إطار CVSS، وتُخصص أولوية زمنية محددة لكل تصنيف.
- 7.5.5 تُراجع نتائج الفحوصات الدورية في اجتماع شهري ويُحدث سجل الثغرات بناءً عليها.
- 7.5.6 اختبار الاختراق (Penetration Testing):

- 7.5.6.1 يجب إجراء اختبار اختراق داخلي وخارجي وتطبيقات الاستضافة على الأقل مرة واحدة سنويًا، أو بعد أي تغيير جوهري

في البيئة التقنية (مثل ترقية البنية التحتية أو إطلاق نظام جديد).

- 7.5.6.2 تُنفذ الاختبارات من قبل جهة متخصصة مستقلة أو فريق داخلي معتمد، وتوثق النتائج بالكامل.

- 7.5.6.3 يجب معالجة جميع الثغرات القابلة للاستغلال التي يتم اكتشافها خلال الاختبار خلال فترة لا تتجاوز 30 يومًا، ويُعاد اختبارها بعد المعالجة للتحقق من الإغلاق.
- 7.5.6.4 تُحفظ تقارير اختبار الاختراق ضمن سجل الثغرات، وتُعرض في تقرير شهري لأمن المعلومات.
- 7.5.7 الفحص الدوري للثغرات (Vulnerability Scanning):
- 7.5.7.1 يجب إجراء فحص دوري لاكتشاف الثغرات الأمنية في الشبكات الداخلية والخارجية مرة واحدة على الأقل كل 3 أشهر، أو فور أي تعديل جوهري في الشبكة.
- 7.5.7.2 تُستخدم أدوات فحص معتمدة مثل Nessus أو Qualys أو ما يعادلها، ويجب أن يشمل الفحص الخوادم، الأجهزة، والأنظمة الحيوية.
- 7.5.7.3 يجب معالجة جميع الثغرات المصنفة "حرجة (Critical)" أو "عالية (High)" خلال فترة لا تتجاوز 14 يومًا، ويُعاد الفحص حتى التأكد من زوالها.
- 7.5.7.4 في حال اكتشاف دليل على اختراق فعلي أو استغلال لأحد الموارد، يُلزم بالإبلاغ الفوري إلى مسؤول الأمن السيبراني وفريق الدعم الفني، مع توثيق الحدث كحادثة أمنية رسمية.
- 7.5.8 تحديث معايير التكوين الأمنية (Security Baseline Updates):
- 7.5.8.1 يجب تحديث معايير التكوين الأساسية (Baseline Configurations) لجميع الأنظمة والخوادم عند ظهور ثغرات جديدة تؤثر على إعداداتها.
- 7.5.8.2 يُلزم الفريق التقني بمراجعة الإعدادات القديمة وتعديلها بما يتماشى مع أحدث توصيات الأمن السيبراني، بالتنسيق مع مسؤول الأمن السيبراني.
- 7.5.8.3 تُوثق جميع التحديثات على خطوط الأساس الأمنية في سجل مستقل يُراجع نصف سنويًا.
- 7.5.9 التحقق من تطبيق التحديثات:
- 7.5.9.1 يجب التحقق من نجاح تطبيق التحديثات الأمنية خلال فترة لا تتجاوز 5 أيام من التنبيه.
- 7.5.9.2 تُستخدم أدوات مراقبة تلقائية لتأكيد اكتمال التطبيق، ويجب تسجيل نتائج التحقق ضمن سجل التحديثات.
- 7.5.9.3 في حال فشل التحديث أو عدم نجاح التنبيه، يُعاد الجدولة فورًا ويُعد تقرير متابعة لفريق تقنية المعلومات.
- 7.6 الحماية من البرمجيات الخبيثة:
- 7.6.1 يجب تثبيت برنامج مكافحة الفيروسات المعتمد Centrally Managed Anti-Malware Solution (مثل Kaspersky Endpoint Security أو Microsoft Defender for Endpoint) على جميع الأجهزة في الشركة، بما في ذلك الحواسيب والخوادم وأجهزة المستخدمين.
- 7.6.2 يُلزم بتحديث قاعدة بيانات الفيروسات تلقائيًا بشكل يومي من خلال خادم الحماية المركزي، وتُراجع تقارير التحديث من قبل مسؤول الأمن السيبراني أسبوعيًا.
- 7.6.3 يُمنع على المستخدمين إيقاف برنامج الحماية أو تعديله بأي شكل، ويجب تفعيل خاصية الحماية من العبث (Tamper Protection) لضمان ذلك.
- 7.6.4 تُفحص جميع وسائط التخزين الخارجية (مثل USB و DVD) عبر برنامج الفحص المعتمد قبل استخدامها، ولا يُسمح باستخدامها دون تصريح خطي من مدير تقنية المعلومات.
- 7.6.5 تُستخدم أدوات تصفية المحتوى الإلكتروني ومنع الوصول إلى المواقع الضارة (مثل Web Filtering أو DNS Filtering Gateways)، وتُحدث قوائم الحظر كل 12 ساعة تلقائيًا.
- 7.6.6 يجب الاحتفاظ بسجل فحص البرمجيات الخبيثة لكل جهاز لمدة لا تقل عن 6 أشهر، ويُراجع هذا السجل شهريًا من قبل مسؤول الأمن السيبراني لاكتشاف أنماط التهديدات المحتملة.
- 7.7 إدارة السجلات والأنشطة:
- 7.7.1 يجب تفعيل التسجيل الكامل لجميع الأنشطة، بما يشمل الدخول، التعديلات، الفشل، والتصعيد.
- 7.7.2 تُرسل السجلات إلى منصة مركزية (مثل Splunk أو Wazuh)، وتُحتفظ بها لمدة سنة على الأقل.
- 7.7.3 تُراجع السجلات أسبوعيًا من قبل مسؤول الأمن السيبراني وتُعد تقارير بالحالات المريبة.
- 7.7.4 تُفعل أدوات تتبع التغيير مثل File Integrity Monitoring (FIM) في أنظمة التشغيل الحيوية.
- 7.7.5 في حال وجود محاولة تعديل غير مصرحة، يُبلغ عنها فورًا وتُعالج خلال 24 ساعة.
- 7.8 حماية البيانات أثناء التشغيل والتخزين والنقل:

- 7.8.1 تُشفّر جميع البيانات المصنفة "سرية" باستخدام AES-256 في قواعد البيانات وأنظمة الملفات.
- 7.8.2 يُستخدم HTTPS في المواقع الداخلية والخارجية وSFTP في النقل بين الخوادم.
- 7.8.3 يُمنع نقل أي ملف حساس عبر البريد الإلكتروني ما لم يُشفّر باستخدام PGP أو ما يعادله.
- 7.8.4 تُحدث سياسات التصنيف كل 6 أشهر بالتعاون مع إدارة الامتثال.
- 7.8.5 تُسجل كل عملية نقل بيانات في سجل خاص يُراجع دوريًا.
- 7.9 6.9 الهيئة الآمنة للأجهزة الطرفية
- 7.9.1 يجب إغلاق جميع منافذ USB افتراضيًا، ويُمنح الاستثناء فقط بموجب طلب موثق ومعتمد من مدير تقنية المعلومات.
- 7.9.2 تُستخدم أدوات التحكم في الأجهزة (Device Control) لمراقبة إدخال أو إخراج البيانات.
- 7.9.3 تُفعل حلول EDR (مثل CrowdStrike) في جميع الأجهزة، وتُربط بلوحة تحكم مركزية لدى فريق الأمن السيبراني.
- 7.9.4 يجب أن يخضع كل جهاز لعملية تحديث وإعادة تهيئة عند انتقاله من مستخدم إلى آخر، وتتم العملية وفق الخطوات التالية:
- 7.9.4.1 يقوم المستخدم السابق بإعادة الجهاز إلى مشرف تقنية المعلومات.
- 7.9.4.2 يقوم الفريق بإجراء مسح كامل للبيانات وفق آلية الحذف الآمن.
- 7.9.4.3 يُعاد تثبيت نظام التشغيل وتطبيق السياسات الأمنية.
- 7.9.4.4 يُسجل الجهاز مجددًا باسم المستخدم الجديد في سجل الأجهزة.
- 7.9.5 تُنفذ هذه العملية من قبل مشرف تقنية المعلومات في إدارة تقنية المعلومات، ويجب توثيق كل عملية نقل أو تهيئة في سجل الأجهزة.
- 7.9.6 في حال فقدان جهاز، يجب تنفيذ المسح عن بُعد خلال ساعتين من البلاغ وتوثيق الإجراء في سجل الحوادث التقنية.
- 7.10 المراقبة والاستجابة للحوادث:
- 7.10.1 يجب تشغيل أدوات SIEM لتوليد التنبيهات التلقائية عند رصد أي سلوك غير اعتيادي.
- 7.10.2 تُدار الحوادث وفق جدول استجابة محدد في سياسة الحوادث، ويُبلغ عنها في خلال ساعة واحدة.
- 7.10.3 يجب أن تُخزن الأدلة الإلكترونية (Logs، صور الشاشة، التقارير) في وحدة تخزين مقيدة الصلاحيات.
- 7.10.4 يُعد تقرير تحليل أولي خلال 48 ساعة، ويرفع لمدير الأمن السيبراني ثم الإدارة العليا.
- 7.10.5 تُناقش الحالات شهريًا في اجتماع مخاطر الأمن المعلوماتي.
- 7.11 أمن الاتصالات اللاسلكية:
- 7.11.1 يجب تسجيل واعتماد كل نقطة اتصال (Access Point) في سجل الشبكة اللاسلكية.
- 7.11.2 تُستخدم WPA3 أو أعلى عند توفرها، مع تعطيل بث اسم الشبكة (SSID) متى ما أمكن.
- 7.11.3 يُمنع تشغيل أي نقطة اتصال شخصية في مقر الشركة.
- 7.11.4 تُجرى عمليات تفتيش ربع سنوية بحثًا عن أجهزة بث لاسلكية غير مصرح بها (Rogue APs).
- 7.12 ضوابط الوصول الفيزيائي:
- 7.12.1 يُلزم بتأمين جميع المواقع الحساسة ببطاقات مغنطة وأنظمة مراقبة فيديو.
- 7.12.2 يجب تفعيل سجل دخول الزوار وتوثيق هوية كل زائر ومكان وجهته ومدة مكوثه.
- 7.12.3 يُراجع نظام الصلاحيات الفيزيائية شهريًا، وتُلغى صلاحيات الموظف خلال 24 ساعة من ترك العمل.
- 7.12.4 يُمنع تخزين أي معدات تقنية في بيئات مفتوحة بدون قفل أو مراقبة كاميرات.
- 7.13 صلاحيات بطاقات الدخول:
- 7.13.1 تُمنح بطاقات الدخول فقط بموافقة مشرف تقنية المعلومات أو لجنة الأمن الفيزيائي.
- 7.13.2 يجب توقيع الموظف على نموذج إقرار بالدخول وسرية المعلومات قبل تفعيل البطاقة.
- 7.13.3 يُمنع مشاركة البطاقات أو إعارتها.
- 7.13.4 تُسحب الصلاحية مباشرة عند الاستقالة أو الانتقال لإدارة أخرى.
- 7.13.5 يُراجع سجل البطاقات كل 3 أشهر وتُلغى غير الضرورية.
- 7.14 مراقبة الزوار:
- 7.14.1 يُشترط وجود مرافق مع الزائر في كل المناطق الخاضعة للرقابة.
- 7.14.2 لا يُسمح للزوار بالتحرك داخل المواقع الحساسة دون تصريح ومرافقة.

7.15 أحكام الأمن الفيزيائي:

- 7.15.1 يجب توقيع جميع الموظفين المصرح لهم بالدخول الفيزيائي إلى مرافق المعلومات على نماذج إقرار الدخول والسرية.
- 7.15.2 يُمنع استخدام بطاقة أو مفتاح دخول من قبل أي شخص آخر خلاف صاحبها، كما يُمنع إعارتها أو مشاركتها.
- 7.15.3 يجب الإبلاغ فوراً عن فقدان أو سرقة بطاقات أو مفاتيح الدخول إلى مشرف تقنية المعلومات، ويجب إلغاء صلاحيتها فوراً.
- 7.15.4 تُراجع صلاحيات بطاقات ومفاتيح الدخول كل 3 أشهر، وتُلغى من لا تتطلب مهامهم استمرار الوصول.
- 7.15.5 يُمنع إعادة تخصيص أي بطاقة دخول لشخص آخر قبل إنهاء إجراءات الإرجاع الرسمية وتوثيقها.
- 7.15.6 يُشترط مرافقة جميع الزوار من قبل موظف مخوّل أثناء تواجدهم داخل المناطق المحمية أو الحساسة.
- 7.15.7 يُمنع نشر أو تداول أي خرائط أو دلائل داخلية تُظهر مواقع أنظمة أو بيانات حساسة.
- 7.15.8 يجب اتخاذ تدابير لحماية أنظمة المعلومات من انقطاعات الكهرباء أو الأعطال في البنية التحتية، مثل توفير مصادر طاقة احتياطية.
- 7.15.9 تُراقب الظروف البيئية (درجة الحرارة والرطوبة) في غرف الخوادم والمرافق الحساسة للتأكد من توافقها مع متطلبات التشغيل الآمن.

7.16 تصنيف وإدارة المعلومات وتطبيقها في الأنظمة:

- 7.16.1 يجب أن تطبق الأنظمة قواعد التحكم في الوصول استناداً إلى التصنيفات التالية:
- 7.16.1.1 عام (Public): معلومات لا تتطلب حماية خاصة ويجوز مشاركتها علناً.
- 7.16.1.2 داخلي (Internal): معلومات يجب حمايتها لأسباب مهنية أو تنظيمية، ولا تُشارك إلا مع موظفين مفوضين.
- 7.16.1.3 سري (Confidential): معلومات حساسة محمية نظامياً أو عقدياً، ويقتصر الاطلاع عليها على من لديهم حاجة وظيفية (Need-to-know).
- 7.16.1.4 حساس جداً (Highly Confidential): مستوى إضافي يستخدم عند الحاجة الماسة لحماية معلومات شديدة الحساسية (كأسرار العملاء أو البيانات النظامية المحمية).
- 7.16.2 دعم الأنظمة للتصنيف:
- 7.16.2.1 تُمنع البرمجيات أو الأنظمة التي لا تدعم تطبيق سياسات التصنيف من الدخول في بيئة الإنتاج. ويُشترط توافقها مع معايير الحماية المدمجة (مثل RBAC، DLP).
- 7.16.2.2 7.16.2.3 التحكم في الوصول التلقائي
- 7.16.2.3 عند تغيير تصنيف أي معلومة أو ملف، يُحدث النظام تلقائياً مستوى الحماية بناءً على قواعد الحماية المعتمدة.
- 7.16.3 التوثيق والتغيير:
- 7.16.3.1 يجب توثيق كل عملية تغيير في التصنيف من خلال سجل إلكتروني يُحدث تلقائياً أو يدوياً من قبل مسؤول النظام، ويُشترط تقديم طلب مبرر مع اعتماد من مسؤول الأمن السيبراني.
- 7.16.4 حماية المعلومات حسب التصنيف:
- 7.16.4.1 الداخلية: تُخزن في بيئات مغلقة (مكاتب مغلقة أو أنظمة داخلية) ويُشترط توقيع اتفاقيات سرية للوصول إليها.
- 7.16.4.2 السرية: تُشفّر أثناء التخزين (at rest) والنقل، ويُمنع إرسالها عبر قنوات غير مؤمنة مثل البريد غير المشفر أو الرسائل الفورية.
- 7.16.4.3 الحساسية جداً: تُخزن في بيئات محكمة الدخول (خزائن مغلقة، غرف محمية بكروت مغنطة)، وتُطبق عليها ضوابط مشددة تشمل تسجيل الدخول، التشفير، وتحديد الصلاحيات الدقيقة.
- 7.16.5 التنبيه والاستجابة:
- 7.16.5.1 تُراجع محاولات اختراق البيانات المصنفة بشكل دوري، وتُبلغ فوراً إلى وحدة الاستجابة للحوادث لاتخاذ الإجراءات اللازمة. كما يجب إبلاغ الإدارة العليا في حال الاشتباه بتسريب أي معلومات سرية.
- 7.16.6 المسؤوليات:
- 7.16.6.1 مستخدم المعلومات: يلتزم بالاستخدام النظامي للمعلومة حسب التصنيف.
- 7.16.6.2 مالك المعلومات: يحدد التصنيف، ويُعتمد منه أي تغيير، ويتحمل مسؤولية مشاركة التصنيف مع الأطراف الأخرى.
- 7.16.6.3 حارس المعلومات: (عادةً من موظفي تقنية المعلومات) يطبق آليات الحماية والتشفير حسب التصنيف المحدد.
- 7.16.7 الاحتفاظ والإتلاف:
- 7.16.7.1 تُخزن المعلومات وفق جدول الحفظ الرسمي المعتمد في الشركة.

- 7.16.7.2 عند انتهاء الحاجة للمعلومة، تُصنف كـ "منتهية" ويتم إتلافها باستخدام آلية معتمدة (حذف آمن / تمزيق ورقي / مسح مشفر).
- 7.16.7.3 لا يُسمح بإتلاف أي معلومة إلا بعد الرجوع إلى مالكيها لتأكيد عدم الحاجة للتمديد.
- 7.17 استعادة الكوارث واستمرارية الأعمال:
- 7.17.1 يجب على شركة داي몬드 لوساطة التأمين إعداد وتنفيذ خطة رسمية لاستعادة الكوارث واستمرارية الأعمال (Disaster Recovery & Business Continuity Plan - DRP)، تهدف إلى ضمان استعادة الأنظمة الحيوية والبيانات الأساسية في حال حدوث انقطاع أو كارثة تقنية أو تشغيلية.
- 7.17.2 يلتزم فريق تقنية المعلومات، بالتنسيق مع لجنة أمن المعلومات، بتحديث وتوثيق خطة الاستعادة بشكل سنوي على الأقل، وإجراء اختبارات دورية لها، وتحليل نتائج الاختبارات لاتخاذ إجراءات تصحيحية وتحسينية فورية.
- 7.17.3 يجب أن تتضمن خطة الاستعادة، كحد أدنى، العناصر التالية:
- 7.17.3.1 تحليل الأثر على الأعمال (Business Impact Analysis - BIA) يشمل تقييم المخاطر، وتصنيف الأصول التقنية حسب حساسيتها وأهميتها التشغيلية.
- 7.17.3.2 تعريف واضح للأنظمة الحيوية والمعلومات الأساسية التي تتطلب استعادة فورية.
- 7.17.3.3 استراتيجيات وقائية تشمل: أنظمة الطاقة غير المنقطعة (UPS)، مكافحة الحرائق، الحماية من تقلبات التيار، والتحكم البيئي في الحرارة والرطوبة والغبار.
- 7.17.3.4 إجراءات نسخ احتياطي منتظمة وتخزين آمن في مواقع خارجية متعددة (offsite).
- 7.17.3.5 خطة تشغيل بديلة (Contingency Plan) توضح آليات استعادة الأنظمة والبيانات خلال فترات التوقف.
- 7.17.3.6 تحديد المسؤوليات التنظيمية لكل إدارة وفريق خلال مراحل الكارثة (الاستجابة - الاستعادة - التشغيل المرحلي).
- 7.17.3.7 إجراءات تصعيد واضحة للإبلاغ عن الحوادث الكارثية، وتفعيل خطة الاستعادة، ومتابعة تنفيذها حتى الاستقرار الكامل.
- 7.17.4 يجب أن تشمل الخطة برامج تدريبية دورية لجميع الأفراد ذوي العلاقة، بالإضافة إلى تنفيذ محاكاة حقيقية لاختبار جاهزية الفرق، وتوثيق نتائج المحاكاة، وتضمينها في تقارير التحسين السنوية.
- 7.17.5 يلتزم جميع الموظفين المعنيين، والموردين الفنيين، بتنفيذ تعليمات خطة الاستعادة فور إعلان حالة الكارثة، كما يجب عليهم الامتثال التام للإجراءات المحددة دون تأخير أو اجتهاد فردي.
- 7.17.6 يُمنع التعامل الاترجالي أو تشغيل أي نظام حيوي متأثر قبل مراجعة خطة الاستعادة المعتمدة والحصول على إذن من مشرف تقنية المعلومات أو مسؤول أمن المعلومات.
- 7.17.7 يجب أن تُحفظ نسخة محدثة من خطة الاستعادة في موقعين منفصلين على الأقل (رقمي ومادي)، وأن تُتاح للجهات ذات العلاقة عند الحاجة، مع ضمان سريتها وعدم تداولها خارج النطاق المخول.
- 7.17.8 تُعد أي مخالفة لهذه السياسة، مثل التأخير في الاستجابة، أو الفشل في تنفيذ الإجراءات المحددة، أو الإهمال في تحديث الخطة، مخالفة جسيمة تُعرض مرتكبها للإجراءات التأديبية وفق أنظمة الشركة، وقد تشمل إنهاء الخدمة أو التبعات القانونية.
- 7.18 دورة تطوير واعتماد سياسة أمن أنظمة تقنية المعلومات:
- 7.18.1 يجب أن تمر سياسة أمن أنظمة تقنية المعلومات بمراحل تطوير واضحة تتضمن:
- 7.18.1.1 التطوير ← المراجعة ← الاعتماد ← التطبيق ← التقييم المستمر، وذلك لضمان توافرها مع احتياجات العمل والمستجدات التنظيمية.
- 7.18.2 يُلزم فريق تقنية المعلومات بتوثيق كل مرحلة ضمن سجل دورة حياة السياسات الأمنية، مع تحديد الجهة المنفذة والتاريخ.
- 7.19 إشراف لجنة الأمن السيبراني:
- 7.19.1 يجب أن تُعرض السياسة على لجنة الأمن السيبراني بشركة داي몬드 (DIB Information Security Committee) لمراجعتها، والتأكد من توافرها مع برنامج أمن المعلومات الشامل.
- 7.19.2 يُلزم مسؤول الأمن السيبراني برفع أي تحديثات جوهرية إلى اللجنة، ولا تُعتمد السياسة إلا بموافقة موثقة من اللجنة.
- 7.19.3 تُحفظ جميع محاضر اعتماد السياسات ضمن سجل رسمي لدى إدارة تقنية المعلومات.
- 7.20 نشر السياسة والتوعية الوظيفية:
- 7.20.1 يجب على إدارة تقنية المعلومات نشر النسخة النهائية المعتمدة من هذه السياسة عبر البوابة الداخلية الرسمية للموظفين.

- 7.20.2 يُلزم كل موظف لديه صلاحيات دخول على أنظمة تقنية المعلومات بالتوقيع على إقرار بالاطلاع على هذه السياسة والالتزام بما ورد فيها.
- 7.20.3 تُنظم إدارة الأمن السيبراني دورات توعوية مرة سنوياً على الأقل، لتثقيف الموظفين بشأن بنود هذه السياسة، وشرح أبرز الضوابط والممارسات السليمة.
- 7.21 قياس الالتزام ومراجعة الامتثال:
- 7.21.1 يجب على مسؤول الأمن السيبراني إجراء مراجعات امتثال شهرية تشمل تحليل السجلات، مراجعة الصلاحيات، والتحقق من تنفيذ ضوابط الأمن.
- 7.21.2 تُعد تقارير تقييم امتثال أمن المعلومات بشكل ربع سنوي، تُرفع إلى الإدارة العليا ولجنة الأمن السيبراني مع التوصيات التصحيحية.
- 7.21.3 يُلزم كل قسم مالك لنظام تقني بالتعاون الكامل مع المراجعات والتقارير، وتوفير الوثائق والدعم المطلوب عند الطلب.

8. مسؤولية السياسة:

- 8.1 إدارة تقنية المعلومات:
- 8.1.1 مسؤولون عن تنفيذ التكوينات الأمنية، إدارة الشبكات، وإغلاق المنافذ والثغرات التشغيلية.
- 8.2 قسم الأمن السيبراني:
- 8.2.1 مسؤولون عن تحليل السجلات، مراقبة الدخول، فحص الثغرات، والاستجابة للحوادث الأمنية.
- 8.3 الإدارات المالكة للأنظمة:
- 8.3.1 مسؤولية عن الإبلاغ عن المشاكل الأمنية، والتعاون في تنفيذ إجراءات الحماية.
- 8.4 إدارة الجودة والتطوير:
- 8.4.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

- 9.1 الحاقاً لتعميم المواصفات الفنية لنظام المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (197/202010)، بتاريخ 27/10/2020.
- 9.2 استخدام نظام المراقبة الرقمي في النقل والحفظ الأمن لتسجيلات وبيانات أجهزة المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (224/202110)، بتاريخ 24/10/2021.
- 9.3 الدليل التنظيمي لأمن المعلومات، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (250/202205)، بتاريخ 26/05/2022.

10. حفظ السياسة:

- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
- 10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقادم المستندات. ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

- 11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داييموند المعتمدة.